CVE-2019-0708

© **Universidad de Palermo** | Prohibida la reproducción total o parcial de imágenes y textos.

UP
Universidad
de Palermo

CVE-2019-0708

Producto o versión

Sistemas operativos vulnerables a la CVE-2019-0708:

- Windows 7 [SP1]
- Windows Server 2003 [SP1- SP2 - R2 SP2]
- Windows Server 2008 [R2 SP1 - SP2]
- Windows Vista [SP2]
- Windows XP [SP2 - SP3]

Estas vulnerabilidades se dan en todas las ediciones y en todos los lenguajes del SO.

UP Universidad de Palermo ©

Causa o consecuencia

Causa:

Es posible que un atacante intente conectarse al sistema destino mediante RDP y al enviar un paquete especialmente diseñado, un atacante puede establecer el valor del ID del canal en algo que el servicio RDP no espera, lo que provoca un error de corrupción de memoria que creará las condiciones para que se produzca la ejecución remota de código. Si el atacante decide seguir con los paquetes diseñados para aprovechar esta falla, la ejecución remota de código se puede lograr con privilegios de usuario del sistema. Esta vulnerabilidad no requiere autenticación para ser explotada, la complejidad es baja y se explota a través de la red.

Consecuencia:

- Divulgación total de la información, lo que resulta en la revelación de todos los archivos del sistema.
- Impacto total en la integridad del sistema, hay una pérdida total de la protección del sistema, lo que da como resultado que todo el sistema se vea comprometido.
- El atacante puede hacer que el recurso que fue afectado no esté disponible por completo.

Dónde - Módulo | Vector

Módulo: la vulnerabilidad se encuentra en el módulo de servicios de escritorio remoto anteriormente conocidos como Servicios de Terminal Server, es decir, dentro del Protocolo de escritorio remoto o RDP.

Vector: el vector de acceso es la conexión a través de la red mediante el servicio de escritorio remoto.

UP Universidad de Palermo ©

Impacto

Vector de acceso: a través de red.

Complejidad de acceso: baja.

Autenticación: no requerida para explotarla.

Tipo de impacto: compromiso total de la integridad del sistema + compromiso total de la confidencialidad del sistema + compromiso total de la disponibilidad del sistema.

UP Universidad de Palermo ©

¿Existe exploit?

El 18 de mayo de 2019, el investigador Valthek publicó en Twitter que había desarrollado un exploit para la CVE-2019-0708 relacionada a RDP y agregaba que era muy peligroso, por lo que no daría detalles sobre el mismo.



UP Universidad de Palermo ©

Solución

No es recomendable exponer el servicio RDP a Internet, se debe bloquear el puerto 3389/tcp en el firewall de borde.

Monitorear las conexiones a tu servicio RDP habilita los logs, customiza y actualiza las firmas de tu HIDS o IPS para que se puedan detectar conexiones anormales y poder tomar alguna acción.

No configurar la regla por defecto en el firewall, asegurándose de solo permitir acceso a los orígenes confiables.

UP Universidad de Palermo ©

Recomendación de expertos

Varios expertos en seguridad manifestaron lo peligroso que podría ser la explotación de este bug y recomendaron, entre otras cosas, cortar el acceso a RDP y limitar su uso interno.

Por tal motivo es importante es mantener el sistema operativo actualizado.

UP Universidad de Palermo ©



© Universidad de Palermo
Prohibida la reproducción total o parcial de imágenes y textos.